

Modulo 2:

Controllo degli accessi e autenticazione

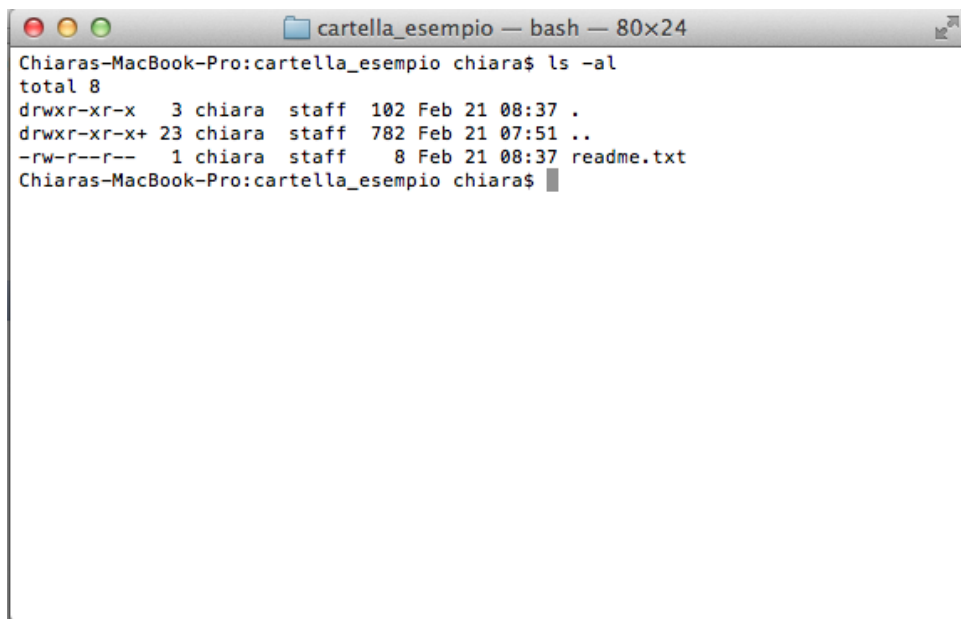
Domande di fine modulo

1 Domande

Quelle che seguono sono delle possibili domande d'esame. La risposta alle domande è facilmente individuabile nel materiale didattico fornito.

1. Descrivere il concetto di *Trojan Horse* e fornire un esempio di come un Trojan Horse possa violare le restrizioni di una politica discrezionale. Provare inoltre a descrivere perché tale Trojan Horse fallirebbe in presenza di una politica mandatoria multilivello.
2. Discutere i principali approcci che possono essere usati per autenticare gli utenti, evidenziando i loro vantaggi e svantaggi.
3. *Access Control List* e *capability list*: cosa rappresentano? Illustrare i vantaggi e gli svantaggi.
4. Nei sistemi operativi Unix-based la password prima di essere memorizzata viene combinata con un *salt*. A cosa serve il *salt*? L'uso del *salt* rende eventuali attacchi all'account di uno specifico utente più difficili rispetto ad attacchi simili eseguiti in sistemi dove il *salt* non viene usato? Motivare la risposta.
5. Nell'ambito delle politiche per il controllo dell'accesso basato sui ruoli, dire cosa si intende con *principio del minimo privilegio* (least privilege). Si richiede di *fornire un esempio*. L'account *root* nei sistemi operativi Unix-based viola questo privilegio? Motivare la risposta.
6. Nell'ambito dei sistemi operativi Unix-based, descrivere il significato dei privilegi *setuid* e *setgid*.
7. In che cosa consiste l'*autenticazione basata sul possesso*?
8. Come vengono gestiti in Unix-Linux i permessi di accesso a file e/o cartelle?
9. In che cosa consiste l'autenticazione basata su *caratteristiche biometriche*?
10. Come vengono memorizzate le password degli utenti nei sistemi operativi Unix-based?
11. In Unix, cosa si intende per *pathname assoluto* e *relativo*?
12. In che cosa consiste l'autenticazione basata sulla *conoscenza*? Quali sono i limiti?
13. Nell'ambito del controllo degli accessi, che cosa è la *matrice degli accessi*?
14. In Unix-Linux, dove vengono salvate le informazioni relative agli *account* degli utenti? In particolare, dove vengono salvate le *password* e come?
15. Spiegare il concetto di *autenticazione* e discutere le tre principali tecniche di autenticazione utente-computer.
16. Descrivere le differenze tra *autenticazione* e *autorizzazione*.
17. In relazione al problema della sicurezza delle password dire cosa si intende per password *spoofing*, *snooping* e *sniffing*.

18. Nell'ambito della tecnica di autenticazione basata sulla conoscenza, descrivere le principali regole per una buona gestione delle password.
19. Nell'ambito delle tecniche di autenticazione basate su caratteristiche biometriche, descrivere il processo di autenticazione.
20. Nell'ambito del modello a matrice di accesso, descrivere le tre tecniche di implementazione della matrice, discutendone i relativi vantaggi e svantaggi.
21. Definire il principio di separazione dei privilegi e fornire un esempio.
22. Caratterizzare i tre meccanismi per il controllo dell'accesso: ACL, capability list e tabella di autorizzazione in termini della facilità con cui è possibile eseguire le seguenti operazioni:
 - data una richiesta di accesso, determinare se la richiesta è permessa oppure no;
 - aggiunta di una autorizzazione per un nuovo soggetto;
 - cancellazione di una autorizzazione per un soggetto;
 - creazione di un nuovo oggetto su cui tutti i soggetti per default hanno il privilegio di lettura;
 - cancellazione di un oggetto.
23. La Figura 1 mostra l'output ottenuto eseguendo il comando `ls -al` all'interno della cartella `cartella_esempio`. Si utilizzi tale figura per spiegare come vengano gestiti i permessi di accesso ai file nei sistemi operativi Unix-based, in particolare spiegando il significato della stringa `-rw-r--r--`.



```
Chiaras-MacBook-Pro:cartella_esempio chiara$ ls -al
total 8
drwxr-xr-x  3 chiara  staff  102 Feb 21 08:37 .
drwxr-xr-x+ 23 chiara  staff  782 Feb 21 07:51 ..
-rw-r--r--  1 chiara  staff   8 Feb 21 08:37 readme.txt
Chiaras-MacBook-Pro:cartella_esempio chiara$
```

Figura 1: Esempio di utilizzo del comando `ls -al`

2 Esercizi

1. Si consideri un sistema Unix con:
 - utente `john`, membro dei gruppi `john` (gruppo principale) e `users`;
 - utente `andrew`, membro del gruppo `andrew`;

- utente nat, membro dei gruppi nat (gruppo principale) e users;
- directory /users/all/files contenente i seguenti file:

Permessi	Owner	Gruppo	Dimensione	Ultima Modifica	Nome File
rwxr-xr-x	andrew	sw	13457	Feb 1 15:05	a.out
rw-r---x	root	dev	3245	Jan 1 00:10	config.init
rw-rw----	john	john	5679	Feb 12 05:05	notes.html
rwsr-s--x	nat	dev	89070	Feb 11 15:10	prova.cgi
rw-rxr-x	nat	users	152	Feb 11 15:10	readme.txt

Rispondere alle domande riportate nella tabella allegata (**Nota:** Le celle non compilate verranno considerate come risposte sbagliate. L'indicazione di file che non fanno parte di una risposta peseranno negativamente sul punteggio finale associato a questo esercizio).

Domanda	Risposta
Elencare i file in /users/all/files che john può leggere.	
Elencare i file in /users/all/files che il processo corrispondente alla esecuzione di a.out da parte di john può scrivere.	
Elencare i file in /users/all/files che andrew può scrivere.	
Elencare i file in /users/all/files che il processo corrispondente alla esecuzione di prova.cgi (da parte di andrew) può eseguire.	